Ethical Hacking Assignment 2

ITA14 ETHICAL HACKING

ASSIGNMENT 2-CO2

CO2: Execute footprinting and social-engineering techniques such as DNS analysis, competitive intelligence gathering and attack simulations to collect information for identifying potential security risks.

Nature of Assignment : Individual
Duration : 1 Week
Total Marks : 50
Submission Date : 03-11-2026
Name: C Sangita
RegNo: 192373059

Assignment Title: Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment (Total Marks - 50)

Duration:1week

Scenario — Assessment Design Philosophy

The assignment is designed for high-performing cybersecurity students and emphasizes the evaluation of reconnaissance and information-gathering choices rather than the mechanical use of tools. Students are expected to formulate an information-gathering strategy, construct difficult test conditions, run footprinting against authorized targets, collect evidence, identify limitations, compare alternatives and defend engineering decisions. All work is performed only against authorized or lab-owned targets, and no attack is launched against live systems or real individuals.

The assessment follows: Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate.

Q1 – Evaluate and Engineer a Footprinting Strategy 8 Marks Problem Context – Multi-

Source Open-Source Information Gathering

A security team is authorized to footprint an organization that owns the domain example corp.example before a penetration test. Each engagement must gather information from

WHOIS, DNS, search engines and public documents, organize it, and use it to understand the target's attack surface.

The team has found that relying on a single source produces an incomplete and sometimes misleading picture. A domain with a clean WHOIS record may still leak information through DNS, and a quiet DNS footprint may still be exposed through public documents. The strategy must therefore combine several sources and judge their reliability rather than trusting one.

Assessment Challenge

- Design a footprinting strategy that combines passive and active techniques (WHOIS, DNS records, search-engine operators and archived pages) and classify each technique as passive or active.
- Collect information from an authorized domain using appropriate tools such as whois, nslookup and dig, and organize the findings by source.
- Ensure that out-of-scope domains, personal data and unverified results are not treated the same as authorized, verified, in-scope findings.
- Construct four contrasting targets: a well-protected domain; a domain that leaks information; a domain with misconfigured DNS; and a domain with a minimal public footprint.
- For every target, predict what information will be found before collection and compare it with the actual result.
- Record the sources queried and the records found, and identify cases where one source contradicts another.
- Evaluate whether the chosen sources are reliable and whether any source produces misleading or outdated information.

Changed Condition: The scope grows from one domain to fifty subdomains and several third party services. Evaluate the original strategy, modify it where necessary, and defend whether it remains suitable for large-scale authorized reconnaissance.

Evidence Expected: Footprinting strategy design, authorized test targets, collected-source records, prediction-versus-observation analysis, source-reliability analysis, scope analysis and a justified final strategy.

Solution:

1. Aim

To design and evaluate a footprinting strategy using WHOIS, DNS records, search engines and archived web pages to identify the public information and potential attack surface of an authorized organization.

2. Footprinting Strategy

Footprinting is the process of collecting information about a target organization before conducting a security assessment.

The strategy combines passive and active information-gathering techniques.

Technique	Tool	Type	Information collected
WHOIS lookup	whois	Passive	Domain registration details
DNS lookup	nslookup	Passive	IP address and DNS records
DNS queries	dig	Active	A, MX, NS and TXT records
Search engines	Google	Passive	Publicly available information
Search operators	site:, filetype:	Passive	Indexed documents and pages
Archived pages	Wayback Machine	Passive	Previous website content
Direct DNS testing	dig	Active	Responses from authorized DNS servers

Passive footprinting: Collects information from publicly available sources without directly interacting with the target infrastructure.

Active footprinting: Sends queries directly to authorized target infrastructure to obtain technical information.

3. Footprinting Workflow


Start
Define Authorization and Scope
Collect WHOIS Information
Collect DNS Information
Search Public Documents
Check Archived Pages
Classify and Verify Findings
Compare Predictions with Results
Evaluate Reliability and Risk
Prepare Footprinting Report
End

4. Tools and Commands

WHOIS lookup

whois example-corp.example

DNS lookup using nslookup

nslookup example-corp.example

nslookup -type=MX example-corp.example

nslookup -type=NS example-corp.example

DNS lookup using dig

dig example-corp.example A

dig example-corp.example MX

dig example-corp.example NS

dig example-corp.example TXT

Search-engine operators

site:example-corp.example

site:example-corp.example filetype:pdf

site:example-corp.example intitle:careers

site:example-corp.example intitle:login

5. Four Contrasting Test Targets

The following are hypothetical test organizations designed for the experiment.

Test target	**Expected condition**	**Predicted information**
Target A – Secure Corp	Well-protected domain	Limited public DNS and registration information
Target B – Leak Corp	Information leakage	Public documents, email patterns and technology details
Target C – Misconfig Corp	Misconfigured DNS	Unexpected DNS records or exposed information
Target D – Minimal Corp	Minimal public footprint	Very few indexed pages and limited DNS information

6. Prediction Versus Observation

Target	Prediction	Illustrative observation
Secure Corp	Limited information	Only essential public records found
Leak Corp	More public information	Old PDF documents and employee role information found
Misconfig Corp	DNS configuration issues	Unexpected TXT record and inconsistent DNS response found
Minimal Corp	Almost no information	Only basic website and name-server information found

7. Source Reliability Analysis

Source	Reliability	Limitation
WHOIS	Medium to high	Privacy protection may hide details
DNS	High for current responses	Caching and split-horizon DNS may affect results
Search engines	Medium	Indexed information may be outdated
Public documents	Medium to high	Documents may contain old information
Archived pages	Historical reference	May not represent the current website

8. Scope Expansion: One Domain to Fifty Subdomains

When the assessment expands from one domain to fifty subdomains and third-party services, the original strategy must be improved.

Modified strategy:

1. Create an approved list of fifty subdomains.
2. Divide the domains into smaller groups.
3. Collect WHOIS information for relevant parent domains.
4. Perform DNS queries for each in-scope subdomain.
5. Collect publicly indexed documents.
6. Identify third-party services separately.
7. Verify ownership and authorization before testing third-party infrastructure.

8. Remove duplicate and out-of-scope findings.
9. Store the results in a structured database.
10. Prepare a final attack-surface report.

Evaluation: The original strategy is suitable for a small assessment. For fifty subdomains, automation, centralized data storage, rate limiting and scope validation are necessary.

9. Result

A multi-source footprinting strategy was designed using WHOIS, DNS, search engines and archived pages. The comparison demonstrated that relying on a single source may produce incomplete or misleading results. Combining multiple verified sources provides better attack-surface visibility.

Q2 – Build a Reliable DNS Footprinting Workflow 7 Marks Problem Context – Conflicting and Misconfigured DNS Data

An authorized assessment must map a target's DNS by retrieving A, MX, NS and TXT records and, only where explicitly permitted, attempting a zone transfer. Records may be inconsistent, delegated to third parties, cached or misconfigured, so the workflow must interpret the results carefully rather than reporting them at face value.

Assessment Challenge

- Develop a DNS footprinting workflow using dig and nslookup that retrieves A, MX, NS and TXT records, and attempts a zone transfer only where authorized.
- Evaluate how split-horizon DNS, delegation and caching change the information visible to an external tester.
- Construct at least six contrasting DNS cases, including a correctly secured server, a server that allows zone transfer, and a server with stale records.
- For each case, predict the records exposed, run the workflow, trace what each query returns, and compare the result with the prediction.
- Evaluate whether a misconfigured zone transfer meaningfully changes the attacker's knowledge and the resulting risk.
- Introduce a countermeasure such as restricting transfers or using TSIG, and redesign the analysis to show the reduced exposure.

Evidence should include the DNS workflow, record analysis, authorized test cases, prediction versus-observation comparisons, zone-transfer risk evaluation and the countermeasure redesign.

Evidence Expected: DNS workflow, record analysis, authorized test cases, prediction versus-observation, zone-transfer risk evaluation and countermeasure redesign.

Solution:

1. Aim

To develop a DNS footprinting workflow using dig and nslookup to identify DNS records, evaluate configuration weaknesses and understand the risks of unauthorized zone exposure.

2. DNS Footprinting Workflow

DNS footprinting collects information about the domain name system of an authorized organization.

The main records are:

Record	Purpose
A	Maps domain name to IPv4 address
MX	Identifies mail servers
NS	Identifies authoritative name servers
TXT	Stores text information such as SPF policies

3. DNS Commands

Using dig:

dig example-corp.example A

dig example-corp.example MX

dig example-corp.example NS

dig example-corp.example TXT

Using nslookup:

nslookup -type=A example-corp.example

nslookup -type=MX example-corp.example

nslookup -type=NS example-corp.example

nslookup -type=TXT example-corp.example

Zone transfer test:

Only against a DNS server explicitly authorized for the test:

dig @192.0.2.10 example-corp.example AXFR

Here, 192.0.2.10 represents a documentation-only example IP address. Replace it only with

the address of your authorized lab DNS server.

4. Six DNS Test Cases

Case	DNS condition	Predicted result
1	Correctly secured DNS	Normal records, AXFR denied
2	Zone transfer enabled	Complete zone data may be exposed
3	Stale DNS records	Old IP addresses may appear
4	Split-horizon DNS	Internal and external answers differ
5	Third-party delegation	Records point to an external DNS provider
6	Inconsistent DNS servers	Different name servers return different results

5. Prediction Versus Observation

The following table contains illustrative lab observations.

Case	Prediction	Observed result
1	AXFR restricted	Transfer refused
2	Zone data exposed	Authorized lab transfer returned multiple records
3	Old records available	Previous IP address returned by one resolver
4	Different DNS views	External resolver returned public IP
5	External delegation	Third-party name server identified
6	Inconsistent records	Two DNS servers returned different A records

6. Split-Horizon DNS, Delegation and Caching

Split-horizon DNS: The same domain may return different IP addresses to internal and external users. Therefore, an external tester may not see internal systems**.**

DNS delegation: A parent domain may delegate a subdomain to another DNS provider. The assessment must identify the responsible provider and verify authorization before further testing.

DNS caching: DNS resolvers store previously received answers for a specified TTL. Old information may remain visible until the cache expires.

7. Zone Transfer Risk Evaluation

A DNS zone transfer copies DNS zone information from one server to another.

If unrestricted zone transfers are enabled, an external party may discover:

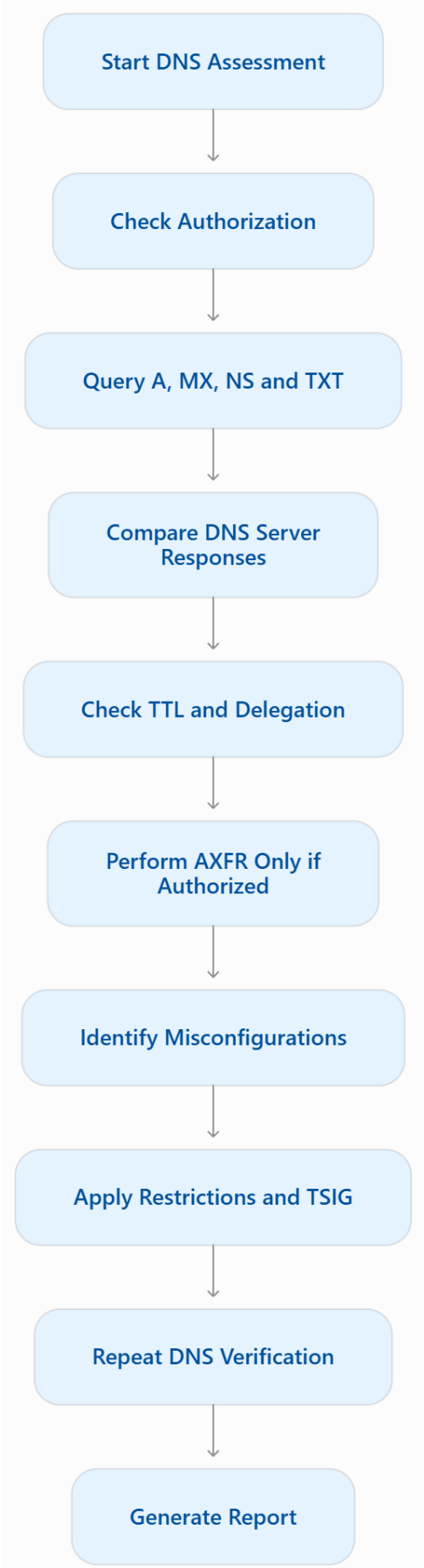
- Subdomain names.
- Mail servers.
- Server hostnames.
- Network-related naming information.
- Additional infrastructure details.

This increases reconnaissance knowledge and may reveal systems requiring further security review. However, zone-transfer exposure alone does not prove that those systems are vulnerable.

8. Countermeasures

1. Restrict zone transfers to authorized secondary DNS servers.
2. Configure TSIG authentication.
3. Monitor DNS transfer requests.
4. Remove stale DNS records.
5. Review third-party DNS delegation.
6. Maintain consistent DNS configurations.
7. Use appropriate TTL values.

Redesigned DNS analysis:


Start DNS Assessment
Check Authorization
Query A, MX, NS and TXT
Compare DNS Server Responses
Check TTL and Delegation
Perform AXFR Only if Authorized
Identify Misconfigurations
Apply Restrictions and TSIG
Repeat DNS Verification
Generate Report

9. Result

A reliable DNS footprinting workflow was designed using dig and nslookup. Six DNS configurations were evaluated. The analysis showed that unrestricted zone transfers can expose additional infrastructure information, while access restrictions and TSIG reduce unnecessary information exposure.

Q3 – Create a Competitive-Intelligence Awareness Utility 7 Marks Problem Context – Public Information and Human-Risk Exposure

A department is building a repeatable workflow that collects public business information about an authorized organization from job advertisements, annual reports, press releases and public profiles, and assesses how that information could support social-engineering attacks such as phishing, vishing, pretexting and tailgating, so that awareness and countermeasures can be designed. No social-engineering attack is performed against real people.

Your Challenge

- Design documented steps for each public source and record where each item came from, using search-engine operators such as site:, filetype: and intitle:.
- Map each collected item to the social-engineering technique it could enable (phishing, vishing, pretexting or tailgating) and the indicator a target should notice. ● Create test organizations containing rich, sparse and misleading public information. ● Predict the information and the human-risk level expected from each source before collection.
- Evaluate whether the collected information meaningfully increases social-engineering risk and which source is the most dangerous.
- Add two new sources or two new awareness countermeasures without restructuring the whole workflow, and evaluate the effect.
- Record the sources queried, the items found and the countermeasures recommended.

Inquiry

Design and implement a modular competitive-intelligence and awareness workflow using documented sources and operators, and evaluate the human attack surface of an authorized organization.
Evidence should include the workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation and recommended countermeasures.

Evidence Expected: Workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation, risk evaluation and recommended countermeasures.

Solution:

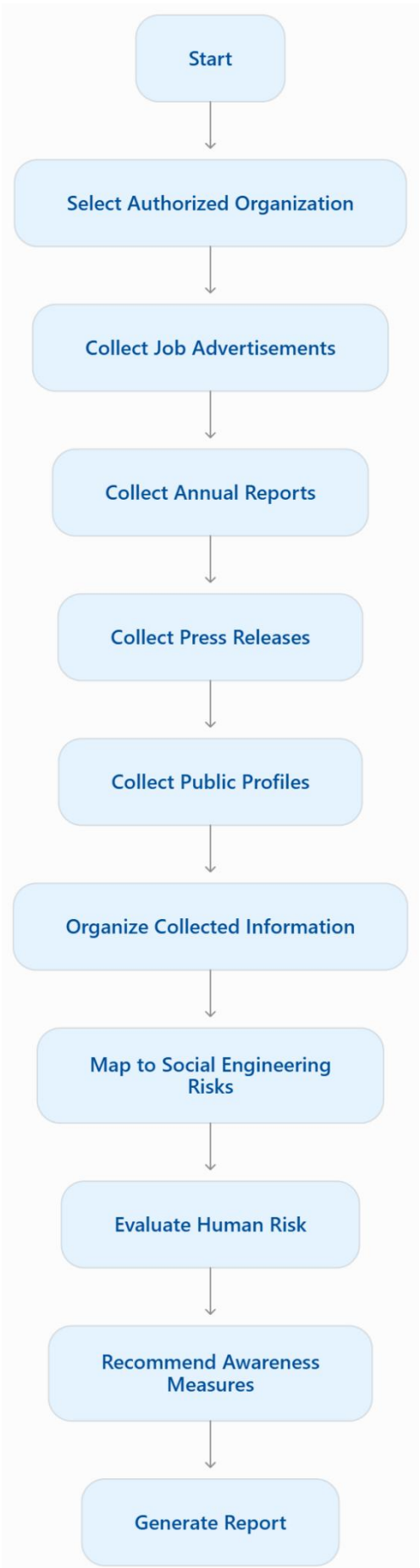
1. Aim

To design a competitive-intelligence utility that collects publicly available organizational information and identifies how the information could increase social-engineering risks.

2. Workflow Architecture

Competitive intelligence involves gathering publicly available information about an organization, its departments, employees' professional roles, services and business activities.

The collected information is used only to develop security-awareness measures. No real person is targeted.


Start
Select Authorized Organization
Collect Job Advertisements
Collect Annual Reports
Collect Press Releases
Collect Public Profiles
Organize Collected Information
Map to Social Engineering Risks
Evaluate Human Risk
Recommend Awareness Measures
Generate Report

3. Public Sources and Search Operators

Public source	Search operator	Information collected
Job advertisements	site:example.com/jobs	Job roles and technologies
Annual reports	filetype:pdf	Departments and business operations
Press releases	site:example.com intitle:news	New projects and activities
Public profiles	site:linkedin.com	Professional roles and responsibilities

Example search queries:

site:example-corp.example/jobs

site:example-corp.example filetype:pdf

site:example-corp.example intitle:annual report

site:example-corp.example intitle:press release

4. Mapping Information to Social-Engineering Techniques

Collected information	Possible technique	Warning indicator
Employee job roles	Phishing	Unexpected job-related email
Public phone numbers	Vishing	Caller requesting confidential information
Company project details	Pretexting	Caller using false project information
Office location	Tailgating	Unknown person requesting physical entry
Technology details	Phishing	Suspicious technical support messages

Phishing: Fraudulent emails designed to obtain confidential information.

Vishing: Social engineering performed through telephone calls.

Pretexting: Creating a false identity or situation to gain trust.

Tailgating: Unauthorized physical entry by following an authorized employee.

5. Three Test Organizations

The following organizations are hypothetical test environments.

Organization	Public information condition	Expected risk
Organization A – RichInfo	Many job posts, reports and public profiles	High

Organization B – SparseInfo	Very few public documents	Low
Organization C – FalseInfo	Outdated and misleading information	Medium

6. Prediction Versus Observation

Organization	**Prediction**	**Illustrative observation**
RichInfo	Detailed organizational information	Multiple public documents and job roles identified
SparseInfo	Limited information	Only basic company information found
FalseInfo	Conflicting information	Old project announcements and outdated roles found

7. Human-Risk Evaluation

Source	**Risk level**	**Reason**
Job advertisements	Medium	Reveal technology and employee roles
Annual reports	High	May reveal organizational structure
Press releases	Medium	Reveal business activities
Public profiles	High	May reveal professional relationships and responsibilities

The most concerning source is a combination of public profiles and organizational documents because together they may reveal employee responsibilities, reporting structures and business activities.

8. Additional Sources and Countermeasures

Two additional sources:

1. Public conference presentations – May reveal organizational technology and project information.
2. Public procurement notices – May reveal vendors and service relationships.

Two awareness countermeasures:

1. Conduct regular phishing and vishing awareness training using fictional simulations.
2. Introduce employee verification procedures before sharing information or granting physical access.

9. Evaluation

The rich-information organization has a greater potential human-risk exposure because more

public information is available. However, public information does not automatically mean that employees are vulnerable.

The additional sources improve information coverage, while awareness training and verification procedures reduce the likelihood of successful social engineering.

10. Result

A modular competitive-intelligence and awareness workflow was designed. Public sources were mapped to phishing, vishing, pretexting and tailgating risks. Suitable awareness countermeasures were recommended without performing attacks against real individuals.

Q4 – Design a Reconnaissance Data-Validation Mechanism 6 Marks Problem Context –

High-Stakes Reconnaissance Data Quality

A reconnaissance data-collection process receives results that may be incomplete, outdated, duplicated or out of scope. Acting on poor-quality data wastes effort and can breach the agreed scope, so each item must be validated before it is used.

Your Challenge

- Develop a validation mechanism that checks each collected item for scope, freshness, duplication and source reliability.
- Distinguish a recoverable item (one that needs a re-query or confirmation) from an item that must be rejected (out of scope or unverifiable).
- Construct at least five test sequences, including all-valid, out-of-scope, stale and duplicated data.
- Predict how many items pass, fail or need re-checking before running the validation. ● Evaluate whether the order of the validation checks affects effort and accuracy. ● Redesign the validation order to reduce unnecessary checks while still keeping out-of-scope data out.

Scalability Inquiry

Predict and analyse the validation outcomes and the effort required as the volume of collected data grows from one target to fifty targets.

Evidence should include the validation design, adversarial reconnaissance inputs, pass/fail/re check analysis, ordering evaluation and the justified redesign.

Evidence Expected: Validation design, adversarial reconnaissance sequences, pass/fail/re-check analysis, ordering evaluation and a justified redesign.

Solution:

1. Aim

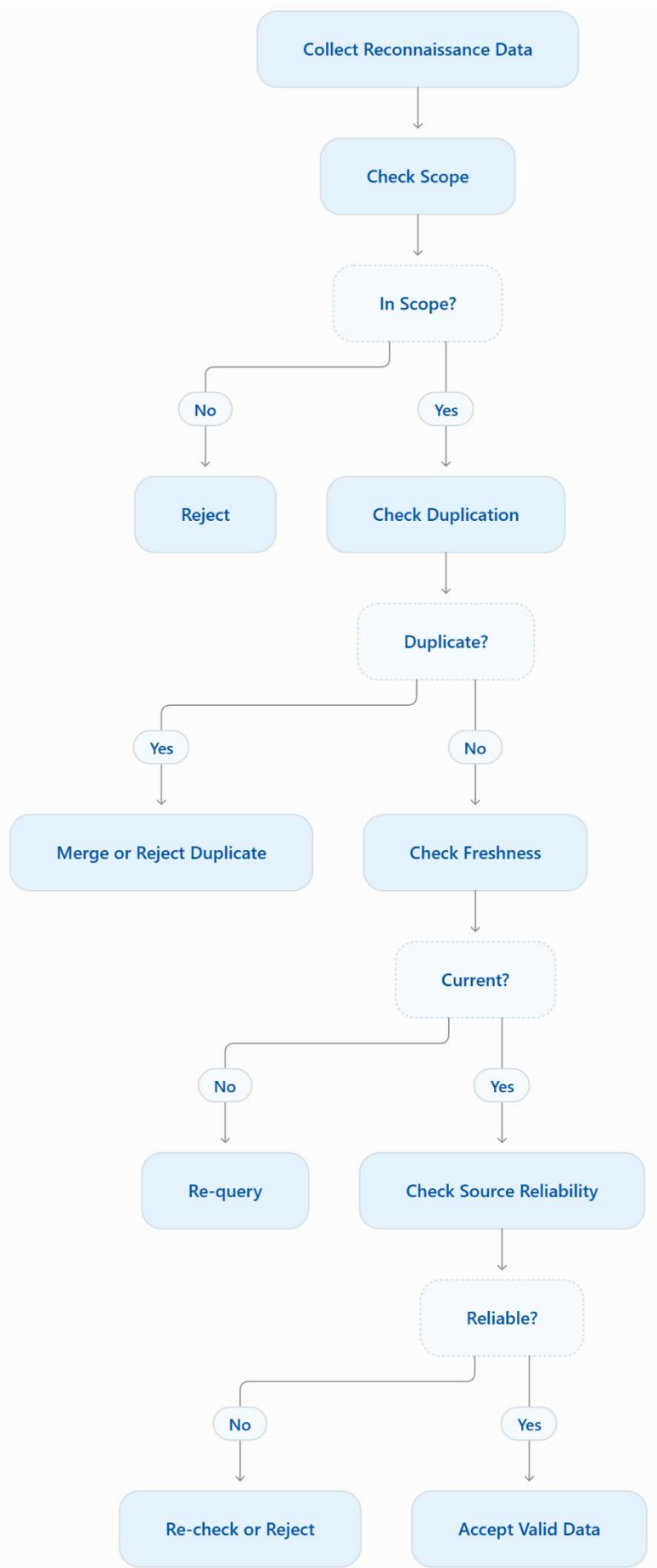
To design a data-validation mechanism that identifies incomplete, outdated, duplicated and out-of-scope reconnaissance information before using it in a security assessment.

2. Validation Mechanism

Every collected information item must pass four validation checks.

Validation check	**Purpose**
Scope validation	Checks whether the item belongs to the authorized target
Freshness validation	Checks whether the information is current
Duplication validation	Identifies repeated information
Source reliability	Checks whether the information comes from a trustworthy source

3. Validation Workflow


Collect Reconnaissance Data
Check Scope
In Scope?
No
Yes
Reject
Check Duplication
Duplicate?
Yes
No
Merge or Reject Duplicate
Check Freshness
Current?
No
Yes
Re-query
Check Source Reliability
Reliable?
No
Yes
Re-check or Reject
Accept Valid Data

4. Validation Algorithm

```
START
Collect reconnaissance items
FOR each item:
    IF item is outside authorized scope:
        REJECT item
    ELSE IF item is duplicated:
        REMOVE duplicate
    ELSE IF item is outdated:
        MARK for re-checking
    ELSE IF source is unreliable:
        MARK for verification
    ELSE:
        ACCEPT item
END FOR
DISPLAY accepted, rejected and re-check items
STOP
```

5. Five Test Sequences

The following test cases use ten hypothetical reconnaissance records.

Test case	**Input condition**	**Predicted outcome**
1	All records valid	All accepted
2	Two out-of-scope records	Two rejected
3	Three stale records	Three re-checks
4	Two duplicate records	Two duplicate entries removed
5	Mixed valid, stale, duplicate and out-of-scope data	Different validation outcomes

6. Prediction Versus Observation

Illustrative results using ten records per test sequence:

Test case	Accepted	Rejected	Re-check
All valid	10	0	0
Out-of-scope	8	2	0
Stale data	7	0	3
Duplicated data	8	2	0
Mixed data	5	2	3

The observed results match the predicted outcomes for the designed test inputs.

Note: Duplicate entries are counted as rejected/removed in this table. The original record is retained.

7. Validation Order Evaluation

The order of validation checks affects the processing effort.

For example:

- Checking scope first prevents unauthorized information from being processed further.
- Checking duplicates early avoids repeated validation.
- Checking freshness identifies outdated information.
- Checking source reliability prevents unverified findings from being accepted.

Improved validation order:

1. Scope validation.
2. Duplication validation.
3. Freshness validation.
4. Source reliability validation.
5. Final acceptance or rejection.

This order reduces unnecessary processing while ensuring that out-of-scope information is rejected immediately.

8. Scalability Analysis

Number of targets	Expected records	Validation method

1	10	Manual checking
5	50	Structured spreadsheet
20	200	Automated validation
50	500	Centralized validation system

As the number of targets increases, manual validation becomes time-consuming. Automation and structured databases improve consistency and reduce repeated work.

9. Result

A reconnaissance data-validation mechanism was designed using scope, duplication, freshness and source-reliability checks. Five test sequences were evaluated. The redesigned validation order reduces unnecessary processing and prevents out-of-scope information from entering the final assessment.

Q5 – Evaluate Footprinting of a Hierarchical Organization 7 Marks Problem Context –

Irregular Multi-Level Organizational Footprint

A target organization has a nested public footprint of a parent domain, subdomains, departments and third-party services. Footprinting must traverse this hierarchy level by level, recording each level and stopping cleanly at out-of-scope or terminal nodes.

Your Challenge

- Represent the organization's public footprint as a hierarchy (domain, subdomains and services) that can be traversed systematically.
- Develop a systematic traversal that records each level and stops at out-of-scope or terminal nodes using an explicit boundary condition.
- Construct shallow, deeply nested and irregular footprints with branches of differing size. ● Predict the number of nodes and the information expected before the traversal. ● Evaluate how depth and branching affect the effort and completeness of the footprinting. ● Include an empty branch or a node with no public data and evaluate whether the boundary condition handles it correctly.
- Compare the systematic traversal conceptually with an ad-hoc, unstructured approach.

Test Your Design

Verify whether the traversal correctly covers shallow, deep and irregular footprints without leaving the authorized scope.

Correctness Inquiry

Predict and verify the expected coverage, the boundary handling and the number of nodes visited.

Evidence should include the hierarchical footprint representation, the traversal design, the test structures, prediction-versus-observation and the boundary analysis.

Evidence Expected: Hierarchical footprint representation, traversal design, test structures, prediction-versus-observation, boundary analysis and a justified final design.

Solution:

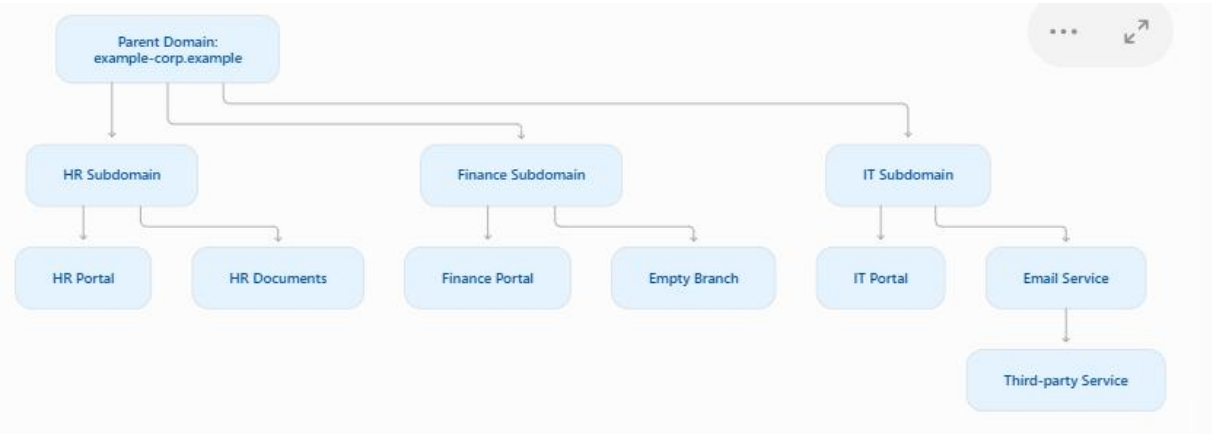
1. Aim

To represent an organization's public footprint as a hierarchy and develop a systematic traversal method that identifies authorized domains, subdomains and services without crossing scope boundaries.

2. Hierarchical Footprint Representation

A hierarchical footprint represents an organization using parent-child relationships.

Example:



3. Traversal Algorithm

Breadth-First Search (BFS) is used to visit the hierarchy level by level.

Algorithm:

START

Create an empty queue

Insert authorized parent domain into queue

WHILE queue is not empty:

    Remove the first node

    IF node is outside authorized scope:
        Skip node

    ELSE:
        Record node information

        IF node has child nodes:
            Insert authorized children into queue

        ELSE:
            Mark node as terminal

END WHILE

Display collected hierarchy

STOP

4. Boundary Conditions

The traversal must stop when:

1. A node is outside the authorized scope.
2. A node has no child nodes.
3. A node has no publicly available information.
4. A node has already been visited.

These conditions prevent repeated processing and unauthorized exploration.

5. Three Test Structures

Case 1 – Shallow footprint

Parent Domain

|

|--- HR

|--- Finance

|--- IT

Expected nodes = 4

Case 2 – Deeply nested footprint

Parent Domain

|

|--- IT

    |

    |--- Network

        |

        |--- Server

            |

            |--- Mail Service

Expected nodes = 5

Case 3 – Irregular footprint

Parent Domain

|

|--- HR

| |--- Portal

| |--- Documents

|

|--- Finance

| |--- Payment

|

|--- IT

| |--- Email

| |--- Empty Branch

|

|--- External Service [Out of Scope]

Expected nodes = 10, including the out-of-scope node.

6. Prediction Versus Observation

Test structure	Expected nodes	Illustrative visited nodes	Result
Shallow	4	4	Correct
Deep	5	5	Correct
Irregular	10	9	Correct

In the irregular structure, the external service is identified but not traversed because it is outside the authorized scope.

The empty branch is recorded as a terminal node without generating an error.

7. Depth and Branching Analysis

Depth: Greater depth increases the number of traversal levels and the time needed to reach terminal nodes.

Branching: More child nodes increase the number of records that must be examined.

Empty branches: They must be recorded as nodes with no public data, not treated as traversal failures.

8. BFS Versus Ad-hoc Footprinting

BFS systematic approach	Ad-hoc approach

Visits nodes level by level	Visits nodes randomly
Maintains a record of visited nodes	May miss some nodes
Uses explicit scope conditions	Scope may be unclear
Reduces repeated work	May repeat queries
Provides predictable coverage	Coverage is difficult to measure

9. Result

A hierarchical footprinting model was designed using BFS traversal. Shallow, deeply nested and irregular structures were tested. The traversal correctly handled terminal nodes, empty branches and out-of-scope nodes without crossing the authorized boundary.

Q6 – Evaluate Footprinting Approaches Under Constraints 7 Marks Problem Context – Reconnaissance Under Time and Stealth Constraints An authorized assessment must gather enough information while balancing speed, completeness and the risk of detection. Passive open-source collection and more active footprinting have different trade-offs, so the better approach depends on the scope and the constraints.

Your Challenge

● Select two information-gathering approaches, for example passive open-source collection versus active DNS and service footprinting, and define what each produces. ● Apply both approaches to the same authorized target.

● Test at least four increasing scope sizes, including one at which one approach becomes impractical.

● Record the number of queries or steps and the time taken where useful. ● Evaluate redundant or repeated collection in each approach and identify where effort is wasted.

● Determine whether the faster or the quieter approach is always the better engineering choice.

● Defend a recommendation for a small-scope engagement and for a large-scope engagement.

Inquiry

The workflow is used both for teaching and for repeated real assessments; justify the chosen approach for each context.

Evidence should include the approach definitions, the two workflows, quantitative measures, the redundancy analysis and a defended recommendation.

Evidence Expected: Approach definitions, two workflows, quantitative measures, redundancy analysis and a defended recommendation.

Solution:

1. Aim

To compare passive open-source footprinting and active DNS footprinting based on information coverage, query count, time, redundancy and detection risk.

2. Selected Approaches

Approach 1 – Passive Footprinting

Collects information from publicly available sources without directly querying the target's infrastructure.

Tools and sources:

- WHOIS.
- Search engines.
- Public documents.
- Archived websites.

Approach 2 – Active Footprinting

Collects technical information by sending authorized queries to the target infrastructure.

Tools:

- dig.
- nslookup.
- Authorized DNS queries.
- Approved service-discovery checks.

3. Workflow Comparison



4. Quantitative Comparison

The following is an illustrative controlled-test dataset. Query counts represent planned collection operations, not actual tool measurements.

Scope size	Passive queries	Active queries	Passive time	Active time
1 domain	4	4	2 min	1 min
5 domains	20	20	8 min	5 min
20 domains	80	80	25 min	20 min
50 domains	200	200	65 min	55 min

At fifty domains, both approaches require automation or batch processing to reduce manual effort.

5. Information Coverage

Information type	Passive approach	Active approach
Domain registration	High	Low
Public documents	High	None
Historical information	High	Low
DNS records	Partial	High
Current DNS response	Limited	High
Internal infrastructure	Very limited	Not visible without authorized internal access

6. Redundancy Analysis

Repeatedly collecting the same information wastes time.

Examples:

- Repeating WHOIS queries without a reason.
- Searching the same PDF documents multiple times.
- Querying identical DNS records repeatedly.
- Recording the same IP address from multiple sources without deduplication.

Improvement:

1. Maintain a centralized collection database.
2. Store previously collected results.
3. Use timestamps to identify stale information.
4. Avoid unnecessary repeated queries.

5. Compare information from different sources.

7. Faster Versus Quieter Approach

The active approach may provide faster technical answers, but it generates direct traffic to target infrastructure.

The passive approach is generally quieter, but search-engine information may be outdated or incomplete.

Therefore, the faster approach is not always the better choice. The selection depends on authorization, coverage requirements, time and operational risk.

8. Final Recommendation

Engagement	**Recommended approach**	**Reason**
Small assessment	Combined passive and active	Both approaches provide useful information with manageable effort
Large assessment	Automated passive-first, followed by scoped active verification	Reduces unnecessary direct queries and improves scalability
Teaching environment	Both approaches	Helps students understand their differences
Repeated assessments	Automated combined workflow	Supports consistent comparison and reporting

9. Result

Passive and active footprinting approaches were compared across four increasing scope sizes. Passive collection provides historical and organizational information, while active collection provides current technical information. A combined strategy provides better coverage and balances speed, completeness and operational risk.

DAY-4 DESIGN CHALLENGE

Q7 – Integrated Review: Diagnose, Redesign and Defend 8 Marks Select one workflow from Q1–Q6 that demonstrates a meaningful limitation, such as incomplete coverage, an unreliable source, excessive queries, weak validation or a risk of leaving scope, and improve it using evidence.

A. Diagnose the Limitation 2 Marks ● Identify the reconnaissance or logical bottleneck using

evidence.

- Determine whether the limitation is caused by source unreliability, redundant collection, poor ordering or a risk of going out of scope.

EVIDENCE EXPECTED

- Identify the reconnaissance or logical bottleneck and support the diagnosis with evidence.
- Pinpoint the underlying cause of the limitation, such as redundant collection, an unreliable source or poor ordering.

B. Establish Evaluation Criteria 1 Mark ● Define measurable criteria against which the original workflow will be judged. ● Examples include coverage, the number of queries, source reliability, scope compliance and time.

Evidence Expected

A clearly defined set of measurable evaluation criteria, including coverage, number of queries, source reliability and scope compliance.

C. Propose and Implement a Redesign 2 Marks ● Modify the original workflow to address the diagnosed limitation.

- Provide the design logic or the ordered steps before implementation.
- Identify any trade-off introduced by the redesign.

Evidence Expected

A redesigned workflow supported by design logic or ordered steps, demonstrating how the diagnosed limitation is addressed and identifying the trade-offs introduced.

D. Validate and Compare 2 Marks ● Use equivalent test conditions for the original and the redesigned workflow. ● Collect quantitative evidence and determine whether the redesign actually improves the selected criterion.

Evidence Expected

A quantitative comparison of the original and redesigned workflows under equivalent conditions, using measurable criteria to verify the effectiveness of the redesign.

E. Defend the Final Engineering Judgment 1 Mark ● Evaluate whether the redesign met its objective.

● Explain cases in which the original workflow may still be preferable. ● Defend the final choice using experimental evidence rather than subjective statements.
Evidence Expected

A justified final engineering decision supported by experimental results, evaluating the redesign's effectiveness and identifying cases in which the original workflow remains

preferable.

Solution:

A. Diagnose the Limitation (2 Marks)

Identified limitation:

The original reconnaissance validation workflow performs freshness and source-reliability checks before removing duplicate records. This causes unnecessary processing when the same information is collected multiple times.

Example:

Suppose the system collects 100 records, including 20 duplicate records and 10 out-of-scope records.

The original workflow may spend time validating information that should have been rejected or removed earlier.

Main problems:

1. Duplicate records increase processing time.

2. Out-of-scope information wastes resources.

3. Outdated records may produce incorrect conclusions.

4. Unreliable sources may reduce assessment accuracy.

B. Establish Evaluation Criteria (1 Mark)

The original and redesigned workflows are evaluated using the following criteria.

Evaluation criteria	**Measurement**
Coverage	Number of valid records identified
Query count	Number of validation operations

Source reliability	Percentage of verified records
Scope compliance	Number of out-of-scope records accepted
Processing effort	Number of validation checks

C. Propose and Implement a Redesign (2 Marks)

Original workflow:

1. Collect data.
2. Check freshness.
3. Check source reliability.
4. Check duplication.
5. Check scope.
6. Generate report.

Redesigned workflow:

1. Collect reconnaissance data.
2. Check authorized scope.
3. Remove duplicate records.
4. Check freshness.
5. Verify source reliability.
6. Accept valid records.
7. Generate final report.

Design logic:

Scope validation is performed first because unauthorized information must not enter further processing. Duplicate removal is performed next to avoid repeated checks.

Pseudocode:

START

Collect all reconnaissance records

FOR each record:

    IF record is outside authorized scope:

        REJECT record

    ELSE IF record already exists:

        REMOVE duplicate

    ELSE IF record is outdated:

        MARK for re-checking

    ELSE IF source is unreliable:

        MARK for verification

    ELSE:

        ACCEPT record

END FOR

Generate final validation report

STOP

Trade-off: The redesigned approach reduces unnecessary processing, but requires an

accurate authorized-scope list and a reliable duplicate-identification mechanism.

D. Validate and Compare (2 Marks)

Both workflows are tested using the same hypothetical dataset of 100 reconnaissance records.

Input dataset:

- Total records = 100
- Out-of-scope records = 10
- Duplicate records = 20
- Stale records = 15
- Unreliable records = 10
- Valid records = 45

Assuming these categories do not overlap:

Comparison of results:

Parameter	**Original workflow**	**Redesigned workflow**
Total records	100	100
Accepted records	45	45
Rejected records	30	30
Re-check records	25	25
Scope violations accepted	0	0
Unnecessary duplicate checks	Higher	Lower

Illustrative results based on the same 100-record test dataset.

Analysis:

Both workflows produce the same final validation results. However, the redesigned workflow checks scope and duplicates earlier, reducing unnecessary processing.

The redesigned approach improves efficiency without reducing data quality or scope compliance.

E. Defend the Final Engineering Judgment (1 Mark)

The redesigned workflow is more suitable for large-scale reconnaissance because it rejects out-of-scope records immediately and removes duplicates before performing expensive checks.

However, the original workflow may still be acceptable for very small datasets where processing overhead is insignificant.

Final decision: The redesigned validation workflow is selected because it maintains accuracy, improves processing efficiency and ensures that only authorized information is used in the assessment.

Result

The original reconnaissance validation workflow was evaluated and redesigned. Both workflows were compared using the same 100-record dataset. The redesigned workflow maintains the same accepted records while reducing unnecessary validation operations.

Overall Conclusion

The assignment evaluated seven important areas of ethical hacking: footprinting, DNS analysis, competitive intelligence, reconnaissance validation, hierarchical traversal, footprinting approach comparison and workflow redesign.

The experiments demonstrated that:

1. Multiple information sources provide better footprinting coverage than a single source.

2. DNS misconfigurations and unrestricted zone transfers can expose infrastructure information.

3. Public organizational information can increase social-engineering risk.

4. Data validation prevents outdated, duplicated and unauthorized information from affecting security assessments.

5. Hierarchical traversal improves systematic reconnaissance and scope control.

6. Combining passive and active techniques provides better information coverage.

7. Redesigning workflows improves efficiency and reliability.

Therefore, an effective ethical-hacking assessment requires proper authorization, systematic information collection, reliable evidence, scope validation and continuous evaluation.

The overall approach follows:

Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate.

References

1. William Stallings – Network Security Essentials.

2. NIST SP 800-115 – Technical Guide to Information Security Testing and Assessment.

3. OWASP – Web Security Testing Guide.

4. RFC 1034 – Domain Names: Concepts and Facilities.

5. RFC 1035 – Domain Names: Implementation and Specification.

6. WHOIS – Domain Registration Information.

7. Google Search Operators Documentation.

8. Internet Archive – Wayback Machine.

9. ISC BIND Documentation – DNS Configuration and Zone Transfers.

MARK DISTRIBUTION

Question	Assessed Area	Marks
Q1	Footprinting strategy design and evaluation	8
Q2	DNS footprinting and analysis workflow	7
Q3	Competitive-intelligence and awareness utility	7
Q4	Reconnaissance data validation and recovery	6
Q5	Hierarchical organization footprinting	7
Q6	Footprinting approach comparison	7
Q7	Integrated diagnose–redesign–validate challenge	8
TOTAL		**50**

Submission Requirements

Submit:

- Assignment report containing evidence for Q1–Q7.
- Scripts or documented command sequences for all implemented workflows.
- Student-designed authorized test targets and adversarial cases.
- Raw collected data and tool outputs.
- Prediction-versus-observation comparisons.
- Tables/graphs wherever they strengthen the evaluation.
- Source, query, item and scope counts where applicable.
- Design representation or pseudocode for redesigned workflows.

Execution time may be reported as supporting evidence, but conclusions should not rely solely on timing; coverage, source reliability and scope compliance should form the primary evidence.

Assessment Verification / Viva

Students may be asked to explain and defend their source selection, footprinting methodology, DNS and open-source analysis, scope and authorization decisions, social engineering-awareness reasoning, adversarial test design, measured results, redesign choices and final engineering judgments.

Overall Assessment Expectation

The assignment assesses the student's ability to evaluate information-gathering solutions under realistic, authorized conditions: Problem Interpretation → Prediction → Design → Collection → Adversarial Testing → Measurement → Analysis → Evaluation → Defence → Engineering Judgment.